UNIT 2 · TOPIC 2.3

Physical Access Controls

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following is an example of a managerial control used in physical security?

- ○ A. A biometric fingerprint scanner installed on the server room door
- ○ B. A reinforced steel door with a deadbolt lock at the building entrance
- **● C. A written policy restricting server room access to IT personnel only**
- ○ D. A surveillance camera mounted above the lobby entrance

Correct answer: C

Why: Managerial (administrative) controls are policies, procedures, and governance documents that direct how security is implemented. A written access-restriction policy is a managerial control. Biometric scanners and reinforced doors are technical/physical controls; a surveillance camera is a technical detective control.

*Why the others are wrong: **A**, Biometric scanners are technical controls, they use technology to enforce access. Students may confuse "high-tech" with "administrative." **B**, A reinforced door is a physical (hardening) control. It prevents entry through physical means, not through policy or procedure. **D**, Surveillance cameras are technical detective controls. They observe and record but do not direct human behavior through governance.*

2. A key card system logs every entry into a restricted research lab, recording the badge ID, timestamp, and door accessed. This system is best classified as which type of security control?

- ○ A. Managerial
- **● B. Technical**
- ○ C. Operational
- ○ D. Physical

Correct answer: B

Why: A key card access system uses electronic/automated technology to enforce and log access, it is a technical control. Technical controls use hardware or software to restrict, detect, or record. Managerial controls are policies; operational controls involve people and procedures; physical controls are tangible barriers like locks and fences.

*Why the others are wrong: **A**, Managerial controls are policy-level. The card system enforces policy but is itself a technical implementation, not the policy itself. **C**, Operational controls are carried out by people (e.g., a guard checking IDs). An automated electronic system is technical, not operational. **D**, Physical controls are tangible barriers, doors, fences, cages. A key card reader is an electronic device layered on top of a physical door, making the reader itself technical.*

3. Which of the following best describes the primary security function of a mantrap (security vestibule)?

- ○ A. To detect unauthorized access attempts through embedded motion sensors and trigger an alarm
- **● B. To prevent tailgating by permitting only one person to pass through at a time before the next door opens**
- ○ C. To create an auditable log of every individual who enters a restricted zone
- ○ D. To alert security personnel when a door is held open beyond a set time threshold

Correct answer: B

Why: A mantrap is a small enclosed area with two interlocking doors: the first door must close and authenticate before the second opens. Its primary purpose is to physically enforce one-person-at-a-time entry, directly preventing tailgating and piggybacking attacks. Detection and logging are secondary capabilities that may be added but are not the defining function of a mantrap.

*Why the others are wrong: **A**, Motion sensors are a detection control, not a mantrap function. Mantraps prevent entry rather than detect it. **C**, Access logging is a function of electronic badge readers that may accompany a mantrap but is not what defines the mantrap itself. **D**, Door-ajar alarms are a separate monitoring control. A mantrap's defining feature is the sequential interlocking door mechanism.*

4. You are on the physical security team at Xtensr Research Labs. After assessing the newly acquired facility, you recommend installing biometric palm scanners at the server room entrance. Which statement best explains how this control mitigates the risk of unauthorized server room access?

○ A. It deters attackers by making the facility appear heavily monitored and difficult to breach

○ B. It provides a recovery mechanism by recording who was present in the server room during a breach

○ C. It detects unauthorized entry attempts in real time and sends an alert to the security team

● D. It prevents unauthorized entry by verifying identity using a physical attribute unique to each person, which cannot be shared or transferred

Correct answer: D

Why: Biometric controls are preventive technical controls that authenticate identity using an inherence factor, something a person physically is (palm vein pattern, fingerprint, iris). Unlike PINs or key cards, biometric credentials cannot be shared, loaned, or easily duplicated, directly preventing unauthorized access. Deterrence (A) and detection (C) describe secondary effects or different controls; recovery/logging (B) describes a detective/corrective function.

*Why the others are wrong: **A**, Deterrence is a valid security benefit but is not the primary mechanism by which biometric scanners mitigate unauthorized access, prevention through authentication is. **B**, Recording presence is a logging/forensic capability, not the primary mitigation provided by biometric access control. **C**, Real-time alerting is a detection function. Biometric scanners primarily prevent entry rather than detect and alert.*

5. Xtensr Labs installs CCTV cameras covering all entry points of the newly acquired research lab. Which of the following best explains how this control mitigates physical security risk?

● A. It deters potential attackers who know they are being recorded and provides forensic evidence to support investigation after an incident

○ B. It prevents unauthorized individuals from entering the facility by blocking physical access to entry points

○ C. It authenticates the identity of employees and grants or denies entry based on recognized faces

○ D. It encrypts communication between security checkpoints to prevent interception by adversaries

Correct answer: A

Why: Standard CCTV systems are primarily detective and deterrent controls. They deter opportunistic attackers who avoid being recorded and capture footage that supports incident investigation and accountability. They do not physically block entry (B), perform identity authentication to grant/deny access (C, that would be facial recognition-based access control, a different system), or handle network encryption (D).

*Why the others are wrong: **B**, Cameras observe but do not physically stop movement. A camera with no accompanying access control or guard cannot prevent entry. **C**, Facial recognition for access control is a distinct, active technical system. Standard CCTV passively records and does not grant or deny entry. **D**, Encryption is a data security control unrelated to CCTV's function in physical access management.*

6. Xtensr Labs requires all visitors to present a government-issued ID to the receptionist, sign a physical visitor log, and wear a temporary visitor badge for the duration of their visit. Which of the following best explains how this managerial control package mitigates physical security risk?

○ A. It prevents all unauthorized persons from entering the facility by creating a physical barrier at reception

○ B. It automatically alerts the security team when a visitor's identity cannot be verified against an internal database

● C. It establishes accountability by creating an auditable record of visitor identity and access, deterring malicious visitors and supporting investigation if an incident occurs

○ D. It encrypts visitor credentials to protect against identity theft during the check-in process

Correct answer: C

Why: Visitor log and badge procedures are managerial (administrative) controls that establish accountability and non-repudiation. They deter malicious actors (who know their identity is recorded), enable post-incident investigation through the audit trail, and create a visible signal (badge color/type) that allows staff to challenge unbadged individuals. They do not physically bar entry (A), trigger automated alerts (B), or involve encryption (D).

*Why the others are wrong: **A**, A sign-in process does not physically stop entry, a determined attacker could walk past the desk. Physical barriers (turnstiles, locked doors) serve that preventive function. **B**, A manual visitor log has no automated alert capability; that would require an integration with a watchlist database system, which is a separate technical control. **D**, Visitor logs are paper or basic digital records; encryption is irrelevant to their primary function of accountability and audit.*

7. During the physical vulnerability assessment of Xtensr Labs' new facility, an assessor observes that employees frequently hold the badge-access door open for colleagues immediately behind them rather than requiring each person to badge in individually. Which control most directly addresses this vulnerability, and why?

○ A. Installing additional CCTV cameras at badge-access doors, because detection of tailgating incidents creates accountability

○ B. Requiring annual security awareness training on tailgating risks, because informed employees are the most cost-effective control against social engineering at doors

○ C. Updating the acceptable use policy to explicitly prohibit piggybacking, because managerial controls set the behavioral standard employees are expected to follow

● D. Implementing a mantrap or security vestibule at high-security entrances, because it physically enforces single-person entry regardless of employee social behavior

Correct answer: D

Why: Tailgating exploits the social tendency to hold doors for others, a behavior that policy and training can reduce but cannot eliminate. A mantrap physically enforces the constraint by mechanically preventing a second person from entering until the first has been authenticated and the entry logged. NIST SP 800-53 PE-3 (Physical Access Control) recommends this type of architectural control for high-security areas. CCTV (A) detects but does not prevent tailgating. Policy (C) and training (B) are valid supporting controls but rely on human compliance and cannot independently close a physical vulnerability in a high-risk zone.

*Why the others are wrong: **A**, Detection creates deterrence and post-incident evidence but does not prevent the tailgating event itself. In a high-security research lab, prevention is the priority. **B**, Training improves awareness but cannot be relied upon as the primary control for a physical access vulnerability. Human behavior under social pressure remains unpredictable. **C**, A policy is a necessary foundational control but provides no enforcement mechanism if employees choose to ignore it. It does not directly close the physical gap.*

8. Xtensr Labs uses badge card readers at all perimeter doors but secures interior server rooms with standard combination locks. A security auditor flags this configuration as a control gap. Which evaluation of this configuration is most accurate and aligned with NIST physical access control principles?

○ A. The configuration is sufficient because perimeter controls represent the highest-priority threat vector and the combination locks provide an adequate secondary barrier

● B. The configuration introduces an accountability gap: combination locks produce no access log, so unauthorized or inappropriate server room access by insiders cannot be detected or investigated after the fact

○ C. Combination locks are more secure than badge readers for interior rooms because knowledge-based authentication (a memorized code) is harder to clone than a physical card

○ D. The configuration is compliant with NIST PE-3 because it uses two distinct control types across different access boundaries

Correct answer: B

Why: NIST SP 800-53 PE-3 requires physical access to be controlled and logged at all sensitive locations, not just the perimeter. Combination locks provide access restriction but generate no audit trail, a critical gap for insider threat scenarios and post-incident forensics. If a server is accessed improperly, there is no record of who entered the room or when. Badge systems create the timestamped, identity-linked logs that NIST access control requirements depend on.

*Why the others are wrong: **A**, Strong perimeter controls reduce external threats but cannot address the insider threat scenario where an authorized employee gains access to a room they should not enter. The server room requires its own access logging. **C**, Combination codes can be shared, observed (shoulder surfing), or remembered by former employees, making them less accountable, not more secure, than individually-assigned badge credentials. **D**, NIST PE-3 does not simply require two distinct control types, it requires that sensitive areas have access logging and enforcement at the point of entry. Using two different weak/unlogged controls does not satisfy the requirement.*

9. A budget-constrained research facility must select between two physical security proposals: (1) biometric scanners on all 12 interior doors, or (2) a formal managerial control package, a mandatory visitor escort policy, a contractor access procedure, and an access review schedule, enforced by the security manager. Which evaluation of these options is most consistent with NIST guidance on security control selection?

○ A. Option 1 is always superior because technical controls are inherently stronger and more reliable than managerial controls

○ B. Option 1 eliminates insider threat risk entirely, making the managerial controls in Option 2 redundant

● C. Option 2 may be cost-effective and rapidly deployable but requires reliable human enforcement and complementary technical controls to close the gaps that managerial controls alone cannot address

○ D. Option 2 is superior because NIST guidance establishes that managerial controls always take precedence over technical controls in the control selection hierarchy

Correct answer: C

Why: NIST SP 800-53 and the Risk Management Framework emphasize selecting controls based on risk level, cost-effectiveness, and complementary coverage, not a fixed hierarchy of control types. Managerial controls are legitimate and valuable, particularly when budget constrains technical options, but they depend on human compliance and enforcement. NIST recommends pairing managerial controls with technical or physical controls where feasible. Option 1 is not always superior (A), control selection depends on the threat model and risk context. Biometrics do not eliminate all insider threat vectors (B), and NIST does not establish a hierarchy where managerial controls always take precedence (D).

*Why the others are wrong: **A**, NIST's control selection guidance is risk-based, not type-based. A managerial control appropriate to the risk level is valid; technical controls are not categorically superior. **B**, Biometrics prevent unauthorized physical entry but do not control what an authorized insider does once inside. Managerial controls addressing behavior remain necessary. **D**, NIST does not rank control types in a hierarchy where managerial controls always dominate. All three control families (managerial, operational, technical) are expected to complement each other.*

10. Which of the following best illustrates the concept of layered physical security (defense in depth)?

○ A. Installing a single, high-grade biometric scanner at the main building entrance

○ B. Placing surveillance cameras at every entrance and corridor in the building

● C. Using a perimeter fence, then a badge-access door, then a locked server cage in sequential order

○ D. Requiring employees to memorize long access codes for all interior doors

Correct answer: C

Why: Layered physical security (defense in depth) means deploying multiple, different types of controls at successive boundaries so that an adversary must defeat each one independently. A perimeter fence (physical barrier), badge-access door (technical access control), and locked server cage (physical asset protection) represent three distinct layers at three different boundaries. A single high-grade control (A) creates a single point of failure. Cameras alone (B) represent only the detection layer. Memorized codes (D) are a single control type applied repeatedly, not true layering.

*Why the others are wrong: **A**, A single high-quality control, however strong, is a single point of failure. If bypassed, the asset is fully exposed. Defense in depth requires multiple independent controls. **B**, Cameras are a detection control. Deploying one type of control extensively is not the same as layering different types of controls at different boundaries. **D**, Repeating the same control type (memorized codes) at multiple doors adds redundancy of the same mechanism but does not constitute a layered security architecture.*

11. In a layered physical security model, what is the term for the strategy of placing multiple sequential, independent access barriers so that an adversary must defeat each one to reach a target asset?

○ A. Zero trust

○ B. Redundancy

○ C. Separation of duties

● **D. Defense in depth**

Correct answer: D

Why: Defense in depth is the strategy of implementing multiple, layered controls so that the failure of any single control does not expose the asset. It originated as a military concept and is central to both physical and cybersecurity architecture. Zero trust (A) is an access-control philosophy assuming no implicit trust regardless of network location. Redundancy (B) duplicates a single control for availability, not layering different controls. Separation of duties (C) is an access management principle requiring multiple people to complete sensitive tasks.

*Why the others are wrong: **A**, Zero trust addresses network access authorization philosophy ("never trust, always verify") rather than physical layering of barriers. **B**, Redundancy ensures a backup if one instance fails (e.g., two locks on the same door of the same type). Defense in depth uses different control types at different boundaries. **C**, Separation of duties is a process and role-based control applied to workflows and permissions, not to the physical layering of access barriers.*

12. Which of the following is NOT typically considered a layer in a physical defense-in-depth security model?

○ A. A perimeter fence with motion-activated security lighting

● **B. A network intrusion detection system monitoring server traffic for anomalies**

○ C. A security guard stationed at the building reception desk

○ D. A badge-access door leading to the server room

Correct answer: B

Why: A network intrusion detection system (NIDS) monitors network traffic for cyber threats, it is a network/technical control operating in the logical domain, not a physical layer. Physical defense-in-depth layers address physical space and access: perimeter barriers (A), personnel controls (C), and access control hardware (D) all operate in the physical domain. Confusing network security controls with physical security controls is a common misconception when both are discussed together under "defense in depth."

*Why the others are wrong: **A**, A perimeter fence with lighting is a classic outer physical layer, combining a physical barrier with a deterrent/detection element (lighting). **C**, A security guard is an operational/physical control that provides both deterrence and response capability at the building boundary. **D**, A badge-access door is a technical access control at an interior physical boundary, a standard layer in physical security architecture.*

13. During the physical vulnerability assessment of Xtensr Labs' new facility, your team documents four vulnerabilities: no perimeter fencing, an unlocked and unmonitored loading dock, no visitor management system, and a server room secured only by a standard key lock. Which combination of layered controls would most effectively address the greatest number of these vulnerabilities?

○ A. Install CCTV at the loading dock and replace the server room key lock with a badge reader

○ B. Install alarm systems throughout the facility and create a visitor sign-in policy

○ C. Post a security guard at the loading dock and issue key cards to all employees for the server room

● **D. Add a perimeter fence, install a badge reader at the loading dock, implement a visitor management system, and upgrade the server room to biometric access control**

Correct answer: D

Why: Option D directly addresses all four identified vulnerabilities with appropriate controls at each boundary: a perimeter fence addresses the lack of site-level control; a badge reader at the loading dock addresses the unmonitored entry point; a visitor management system addresses the accountability gap for visitors; and biometric access adds authentication strength and auditability at the server room. Options A and C address only two vulnerabilities. Option B (alarms and a policy) provides detection and administrative guidance but does not directly close the physical access gaps at the perimeter, dock, or server room.

*Why the others are wrong: **A**, CCTV at the dock is a detection control, not a prevention control for an unlocked dock. This option leaves two vulnerabilities (perimeter, visitor management) entirely unaddressed. **B**, Alarms are detective controls; a visitor policy is managerial.*

Neither physically secures the loading dock, fences the perimeter, or strengthens server room access control at the authentication level. ***C****, A guard at the dock and key cards address two vulnerabilities but leave the perimeter and visitor management gaps open. Key cards also lack the auditability of badge or biometric systems.*

14. Xtensr Labs is particularly concerned about insider threats, specifically, employees accessing server rooms they have no legitimate business reason to enter. Which layered set of controls would most effectively mitigate this risk?

○ A. Install surveillance cameras in all hallways and post a security guard outside the server room door

○ B. Require all employees to sign a policy acknowledging that server room access is restricted to authorized personnel

● C. Implement role-based badge access so only personnel with authorized roles can unlock server room doors, log all access attempts with timestamps, and conduct weekly access log reviews

○ D. Install physical locks on all server racks inside the room as the primary safeguard

Correct answer: C

Why: Insider threats require controls that both prevent unauthorized access and create an accountable record for review. Role-based badge access (technical, preventive) restricts entry to authorized roles; access logging (technical, detective) records every attempt; and weekly log review (managerial/operational) ensures anomalies are caught promptly. This is a three-layer approach combining prevention, detection, and review. Cameras and a guard (A) detect but do not prevent an employee from entering if they have a key. Policy alone (B) provides no enforcement. Rack locks (D) are an asset-level control that does not prevent room access.

Why the others are wrong: ***A****, Cameras and guards are detective and deterrent controls. A camera cannot stop a badge-holding employee from walking in; a guard creates a bottleneck but may be bypassed or social-engineered.* ***B****, A signed policy establishes accountability if a violation is later discovered but provides no real-time prevention or detection of unauthorized access.* ***D****, Rack locks are an inner-layer asset control. They do not prevent employees from entering the room itself, which is the threat being addressed.*

15. The newly acquired Xtensr Labs facility has a single main entrance with no access control and interior rooms secured only by standard pin-tumbler locks. Which assessment of this security posture and recommended layered control additions is correct?

○ A. The posture is acceptable; pin-tumbler locks are a recognized industry standard sufficient for interior research rooms

● B. The posture is insufficient at both boundaries; implementing a mantrap or badge reader at the main entrance and role-based badge access on interior rooms would add prevention at the perimeter and accountability inside

○ C. The highest risk is at the perimeter; installing a badge reader at the main entrance and adding a visitor sign-in system would adequately address all identified vulnerabilities

○ D. The highest risk is insider threat; surveillance cameras and a door-ajar alarm system would best close both the perimeter and interior gaps

Correct answer: B

Why: The facility has two distinct control gaps: an uncontrolled main entrance (perimeter boundary) and unaccountable interior room access (inner boundary). A mantrap or badge reader at the entrance closes the perimeter gap with a preventive technical control. Role-based badge access on interior rooms adds authentication and logging at the inner boundary. Together these address both boundary vulnerabilities with layered, complementary controls. Option A dismisses the risks. Option C addresses only external access and leaves interior rooms unchanged. Option D's cameras and alarms are detective controls that do not prevent entry.

Why the others are wrong: ***A****, Pin-tumbler locks provide basic physical resistance but generate no access logs and can be copied or picked, making them insufficient for a research lab with sensitive assets.* ***C****, Addressing only the perimeter leaves interior vulnerabilities open. An adversary who gains entry, or an insider, faces no access control within the building.* ***D****, Cameras and alarms detect events after they occur but do not physically prevent unauthorized entry or distinguish between authorized and unauthorized interior room access.*

16. NIST SP 800-53 recommends applying physical security controls at multiple nested boundaries: site perimeter, building perimeter, work area, and asset level. Xtensr Labs has strong outer controls, a perimeter fence, a staffed guard post, and CCTV at all entry points, but no asset-level controls: server racks are unlocked and storage media is unencrypted. Which evaluation of this configuration is most accurate?

○ A. The configuration is sufficient because perimeter controls represent the highest-impact threat vector and prevent the vast majority of attacks

○ B. The configuration aligns with NIST PE-3 because it uses three distinct outer-layer control types, satisfying the layered control requirement

○ C. Asset-level controls are unnecessary in a research setting where all staff have undergone background checks and are considered trusted

● D. The configuration creates a single-layer failure mode: an adversary or insider who bypasses or is already inside the perimeter gains unrestricted access to all assets, with no inner control to limit the damage

Correct answer: D

Why: NIST SP 800-53 PE-3 and the broader defense-in-depth philosophy require that each boundary layer independently limit exposure, not that one strong outer layer substitutes for inner layers. An insider with legitimate building access, or an external attacker who tailgates past the perimeter, encounters no further resistance before reaching servers and removable media. Asset-level controls (locked racks, encrypted drives) ensure that even a successful boundary breach yields limited access to sensitive data. Strong perimeters are necessary but not sufficient under NIST's multi-boundary model.

*Why the others are wrong: **A**, No control eliminates 100% of threats. Perimeter controls address external adversaries but leave insider threats, social engineering, and perimeter breach scenarios entirely unmitigated at the asset level. **B**, PE-3 requires access control and logging at the point of entry for sensitive locations, not only at the outer perimeter. Concentrating all three control types at the perimeter does not satisfy the inner-boundary requirements. **C**, Background checks are a managerial vetting control, not a substitute for access controls during employment. Insider threats frequently involve trusted employees acting maliciously or negligently.*

17. Xtensr Labs has a layered physical security architecture: badge readers at building and server room entries, CCTV at all entry points, motion sensors active after hours, and a visitor log at reception. Despite these controls, a recent audit found that former employees' badges were not deactivated within 24 hours of termination on three separate occasions. Which analysis most accurately identifies the critical control gap and the most appropriate corrective layer to add?

● A. The gap is in the managerial layer; a formal, policy-enforced offboarding procedure that mandates immediate badge deactivation upon termination, with verification by HR and the security team, is the missing control

○ B. The gap is in the detection layer; deploying additional cameras with facial recognition at entry points would identify and flag former employees attempting to enter

○ C. The gap is in the technical layer; replacing badge readers with biometric scanners would prevent former employees from accessing the building because their biometric profiles would be removed upon termination

○ D. The gap is in the physical layer; rekeying all locks after each employee termination would prevent former employees from returning

Correct answer: A

Why: The technical controls (badge readers, CCTV, motion sensors) are functioning correctly. The failure is procedural: no enforced process exists to ensure badge deactivation happens at the moment of termination rather than days later. This is a managerial/operational control gap, specifically, an offboarding procedure with clear ownership, timeline, and verification steps. No additional technical control can compensate for a missing procedure: adding cameras (B) detects an entry that the procedure gap already permits; switching to biometrics (C) creates the same gap unless biometric profile removal is also procedurally enforced; rekeying locks (D) is impractical and addresses the wrong control layer.

*Why the others are wrong: **B**, Facial recognition at doors detects a former employee during an intrusion attempt but does not close the window of time between termination and deactivation during which the badge is still valid. **C**, Biometric systems face the same deactivation-delay problem as badge systems if no procedure mandates prompt removal of the profile. The control type is irrelevant if the*

process gap is not addressed. ***D****, Rekeying is expensive, disruptive, and operationally impractical after every termination. It also addresses physical key locks, not the badge access system identified in the scenario.*

18. Xtensr Labs must present a physical security investment recommendation to executive leadership. The choice is between: (1) a single high-investment solution, biometric scanners on all 12 interior doors, or (2) a layered architecture investing in a perimeter fence, badge readers at two main entries, a visitor management system, locked server racks, and a formal offboarding procedure. The facility's threat model includes both external adversaries and potential malicious insiders across 6 interior zones and 2 exterior entry points. Which argument best supports the layered architecture in alignment with NIST physical security principles?

○ A. Layered controls are always less expensive per security zone and therefore represent better budget allocation

○ B. Biometric scanners at every interior door fully eliminate tailgating risk and constitute their own layered architecture because they require two factors: presence and biometric identity

● C. A layered architecture ensures that the compromise of any single control, whether by tailgating, credential theft, or an insider, does not expose all assets; different control types address different threat actors and failure modes simultaneously across all boundaries

○ D. The layered architecture is superior because NIST requires organizations to implement controls from all three families, managerial, operational, and technical, and Option 1 uses only a technical control

Correct answer: C

Why: The core NIST defense-in-depth rationale is that layered controls limit the blast radius of any single control failure. Option 2 deploys controls at multiple boundaries (site perimeter, building entry, asset level) and across multiple control families (physical fence, technical badge readers, technical rack locks, managerial offboarding procedure), meaning that a tailgating attacker who bypasses the perimeter still faces badge access; an insider who enters legitimately still cannot access locked racks without additional authorization. Option 1 concentrates investment on a single boundary (interior doors), leaving the perimeter, visitor management, and asset layers unaddressed. The argument in C reflects the actual security value of layering, not cost (A, which is not always true), not a biometric-specific claim (B, which misrepresents what "layered" means), and not a rigid NIST checklist argument (D, which while partially true, understates the actual risk-based reasoning).

Why the others are wrong: ***A****, Cost-per-zone is not always lower for layered controls, and cost alone is not NIST's primary basis for control selection. Risk reduction and coverage across threat vectors are the central arguments.* ***B****, A biometric scanner uses one authentication factor (inherence). Adding biometrics to all interior doors does not constitute layering across different boundaries, it applies the same control type at the same boundary type repeatedly.* ***D****, While NIST does encourage use of all three control families, the recommendation is risk-based, not a mandatory checklist. The stronger argument is the defense-in-depth risk rationale (C), not a compliance-driven statement.*